



REDE HOSPITALAR CUIDAR

Projeto de Infraestrutura de Redes

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

PSI — Versão 1.0

Vigência: Junho de 2026

Belo Horizonte, 2026
PUC Minas — Sistemas de Informação

HISTÓRICO DE REVISÕES

Versão	Data	Descrição	Autor
1.0	Junho / 2026	Versão inicial — elaboração e aprovação	Equipe Eixo 5

SUMÁRIO

1. Introdução	4
1.1 Objetivo	4
1.2 Escopo	4
2. Princípios de Segurança	4
2.1 Confidencialidade	4
2.2 Integridade	5
2.3 Disponibilidade	5
3. Gerenciamento de Acesso	5
3.1 Controle de Acesso	5
3.2 Autenticação	5
3.3 Autorização	6
4. Segurança Física e Ambiental	6
4.1 Proteção de instalações	6
4.2 Controle de acesso físico	6
4.3 Segurança ambiental	6
5. Segurança de Redes e Comunicações	7
5.1 Proteção de redes	7
5.2 Monitoramento e detecção de intrusões	7
6. Gestão de Incidentes de Segurança	7
6.1 Resposta a incidentes	7
6.2 Relatórios de incidentes	8
7. Conscientização e Treinamento em Segurança	8
7.1 Programa de conscientização	8
7.2 Treinamento em segurança	8
8. Avaliação e Melhoria Contínua	8
8.1 Auditorias de segurança	8
8.2 Revisão de políticas e procedimentos	9
8.3 Análise de riscos	9
8.4 Medição de desempenho	9
9. Conformidade Legal e Regulatória	9
9.1 Conformidade com leis e regulamentações	9
9.2 Gerenciamento de vulnerabilidades e patches	10
10. Responsabilidades	10
10.1 Direção	10
10.2 Equipe de segurança da informação	10

10.3 Funcionários	10
Glossário	11

1. Introdução

A presente Política de Segurança da Informação (PSI) da Rede Hospitalar Cuidar foi elaborada com o propósito de formalizar as estratégias, diretrizes e responsabilidades adotadas pela organização para a proteção de seus ativos de informação. Em consonância com os objetivos do negócio e com as exigências regulatórias aplicáveis ao setor de saúde, este documento traduz o compromisso institucional com a preservação da confidencialidade, da integridade e da disponibilidade das informações gerenciadas em todas as unidades da rede.

1.1. Objetivo

Esta política tem como objetivo estabelecer as diretrizes e os requisitos necessários para garantir a segurança da informação em toda a Rede Hospitalar Cuidar, abrangendo a Matriz em Belo Horizonte e as unidades remotas: Secretaria, UPA 1, UPA 2 e UPA 3. Busca-se assegurar a proteção de dados sensíveis de pacientes, prontuários eletrônicos, sistemas clínicos e toda a infraestrutura de tecnologia da informação que suporta as operações hospitalares.

1.2. Escopo

Esta política se aplica a todos os colaboradores, prestadores de serviço, fornecedores e parceiros que, de forma direta ou indireta, acessem, processem, armazenem ou transmitam informações pertencentes à Rede Hospitalar Cuidar. Abrange todos os ativos de informação, incluindo sistemas, servidores físicos e virtuais, infraestrutura de rede, serviços em nuvem e dispositivos de acesso utilizados no domínio minasgerais.net.

2. Princípios de Segurança

A Política de Segurança da Informação da Rede Hospitalar Cuidar fundamenta-se na tríade clássica da segurança da informação, reconhecida internacionalmente pela norma ABNT NBR ISO/IEC 27001, adaptada ao contexto crítico de um ambiente hospitalar:

2.1. Confidencialidade

Assegurar que as informações sejam acessadas exclusivamente por pessoas devidamente autorizadas. No contexto hospitalar, isso implica na proteção rigorosa de prontuários eletrônicos, laudos, dados de identificação de pacientes e registros clínicos, em conformidade com a Lei Geral de Proteção de Dados Pessoais (LGPD — Lei nº 13.709/2018) e com as diretrizes do Conselho Federal de Medicina (CFM).

2.2. Integridade

Garantir a precisão, consistência e completude das informações e dos sistemas de informação ao longo de todo o seu ciclo de vida. Registros médicos adulterados ou corrompidos podem representar risco direto à vida de pacientes, razão pela qual mecanismos de controle de integridade são considerados críticos nesta política.

2.3. Disponibilidade

Assegurar que os sistemas de informação e os recursos de TI estejam prontamente acessíveis quando necessário, especialmente em situações de emergência médica. A infraestrutura da Rede Hospitalar Cuidar foi dimensionada com links de 152 Mbps para a Matriz e 42,4 Mbps para as filiais, visando garantir disponibilidade contínua dos serviços críticos.

3. Gerenciamento de Acesso

3.1. Controle de Acesso

Implementar controles de acesso baseados no princípio do menor privilégio, garantindo que cada colaborador acesse somente os recursos estritamente necessários ao desempenho de suas funções. O controle de acesso é gerenciado centralmente por meio do Active Directory implantado na instância EC2 (Windows Server 2016 Datacenter, domínio minasgerais.net), com Unidades Organizacionais (OUs) segmentadas por cidade e perfil de usuário.

3.2. Autenticação

Estabelecer processos robustos de autenticação para verificar a identidade dos usuários que acessam os sistemas e informações da rede hospitalar. São definidas as seguintes diretrizes:

- Senhas com no mínimo 12 caracteres, combinando letras maiúsculas, minúsculas, números e caracteres especiais;
- Troca obrigatória de senha a cada 90 dias, conforme GPO aplicada no domínio minasgerais.net;
- Bloqueio de conta após 5 tentativas de acesso malsucedidas;
- Autenticação multifator (MFA) obrigatória para acesso remoto e sistemas clínicos críticos.

3.3. Autorização

Garantir que os usuários autorizados possuam permissões apropriadas, revisadas periodicamente. As autorizações são concedidas com base na função exercida pelo colaborador (RBAC — Role-Based Access Control) e gerenciadas por meio das Políticas de Grupo (GPOs) configuradas no Active Directory do domínio minasgerais.net.

4. Segurança Física e Ambiental

4.1. Proteção de instalações

Implementar medidas para proteger as instalações físicas onde os sistemas de informação e recursos de TI estão localizados, incluindo o datacenter da Matriz em Belo Horizonte e os ambientes de servidor das unidades remotas. Salas de servidores devem ter acesso restrito, monitoramento por câmeras e registro de entrada e saída de pessoas.

4.2. Controle de acesso físico

Estabelecer mecanismos de controle de acesso físico para impedir o acesso não autorizado a áreas críticas, como salas de servidores, racks de rede e centros de controle de monitoramento. O acesso deve ser concedido somente a colaboradores com necessidade operacional comprovada, mediante registro formal.

4.3. Segurança ambiental

Implementar medidas para proteger os recursos de TI contra riscos ambientais, incluindo instalação de sistemas de combate a incêndio, controle de temperatura e umidade nas salas de servidores, além de proteção contra surtos elétricos por meio de nobreaks (UPS) e sistemas de energia redundante. Para o ambiente em nuvem, a infraestrutura AWS na região us-east-1 oferece redundância geográfica como camada adicional de proteção.

5. Segurança de Redes e Comunicações

5.1. Proteção de redes

Implementar controles para proteger a infraestrutura de rede da Rede Hospitalar Cuidar contra ameaças externas e internas. A segmentação da rede em sub-redes /24 por unidade (bloco 10.0.0.0/8) limita o impacto de eventuais incidentes de segurança, impedindo o movimento lateral não autorizado entre segmentos. Firewalls devem ser configurados em todas as bordas de rede, com regras de filtragem baseadas no princípio de menor permissão.

5.2. Monitoramento e detecção de intrusões

A Rede Hospitalar Cuidar utiliza o Zabbix Appliance como plataforma centralizada de monitoramento, coletando telemetria de CPU, memória RAM, I/O de disco e tráfego de rede de todos os servidores da infraestrutura. Alertas de limiar devem ser configurados para identificar comportamentos anômalos que possam indicar tentativas de intrusão, indisponibilidade de serviços ou ataques de negação de serviço (DDoS).

6. Gestão de Incidentes de Segurança

6.1. Resposta a incidentes

Estabelecer um processo formal de resposta a incidentes para lidar com violações de segurança e minimizar seu impacto sobre os serviços hospitalares. O plano de resposta a incidentes deve contemplar as fases de identificação, contenção, erradicação, recuperação e análise pós-incidente. Dado o caráter crítico do ambiente hospitalar, o tempo máximo de resposta inicial a incidentes de alta severidade é definido em 30 minutos.

6.2. Relatórios de incidentes

Todos os colaboradores são responsáveis por reportar imediatamente qualquer incidente de segurança identificado à equipe de TI da Rede Hospitalar Cuidar. O reporte deve ser realizado por canal formal definido pela organização. A cultura de reporte deve ser incentivada sem caráter punitivo imediato, de forma a garantir a rastreabilidade rápida dos incidentes e facilitar a comunicação aos órgãos competentes, incluindo a Autoridade Nacional de Proteção de Dados (ANPD), quando aplicável.

7. Conscientização e Treinamento em Segurança

7.1. Programa de conscientização

Desenvolver e implementar um programa contínuo de conscientização sobre segurança da informação, garantindo que todos os colaboradores da Rede Hospitalar Cuidar — incluindo profissionais de saúde, equipes administrativas e de suporte — compreendam suas responsabilidades e a importância da proteção de dados de pacientes. O programa deve abordar temas como engenharia social, phishing, uso seguro de senhas e proteção de dados pessoais sensíveis.

7.2. Treinamento em segurança

Fornecer treinamento em segurança da informação de forma regular, ao menos anualmente ou sempre que houver alterações significativas nas políticas, tecnologias ou ameaças. Novos colaboradores devem receber treinamento introdutório sobre esta PSI como parte do processo de integração (onboarding), antes de receberem credenciais de acesso aos sistemas da rede.

8. Avaliação e Melhoria Contínua

8.1. Auditorias de segurança

Realizar auditorias de segurança periódicas, com frequência mínima anual, para avaliar a eficácia das políticas e práticas de segurança implementadas e identificar áreas de melhoria. As auditorias devem contemplar revisão de acessos, análise de logs dos servidores Ubuntu (192.168.18.75) e Windows Server (domínio minasgerais.net), verificação de conformidade com esta PSI e avaliação da postura de segurança da infraestrutura AWS.

8.2. Revisão de políticas e procedimentos

Esta PSI deve ser revisada e atualizada periodicamente, com intervalo máximo de 12 meses, ou sempre que ocorrerem mudanças tecnológicas relevantes, surgimento de novas ameaças ou incidentes de segurança que evidenciem lacunas nas diretrizes vigentes. Toda revisão deve ser formalmente aprovada pela direção da organização.

8.3. Análise de riscos

Realizar análises de risco para identificar, avaliar e priorizar os riscos de segurança associados aos ativos de informação da Rede Hospitalar Cuidar, implementando medidas proporcionais para sua mitigação. A análise de riscos deve considerar o impacto potencial sobre a disponibilidade dos serviços médicos e a confidencialidade dos dados de pacientes.

8.4. Medição de desempenho

Estabelecer métricas e indicadores-chave de desempenho (KPIs) para medir a eficácia dos programas de segurança. Exemplos de KPIs aplicáveis ao contexto da Rede Hospitalar Cuidar incluem: tempo médio de detecção de incidentes, percentual de colaboradores treinados em segurança, número de vulnerabilidades identificadas e corrigidas por ciclo de auditoria, e disponibilidade mensal dos serviços críticos monitorados pelo Zabbix.

9. Conformidade Legal e Regulatória

9.1. Conformidade com leis e regulamentações

Garantir que todas as políticas e práticas de segurança da Rede Hospitalar Cuidar estejam em conformidade com o arcabouço legal e normativo aplicável, incluindo:

- Lei Geral de Proteção de Dados Pessoais (LGPD — Lei nº 13.709/2018): proteção de dados pessoais e dados pessoais sensíveis de pacientes;
- Marco Civil da Internet (Lei nº 12.965/2014): princípios de privacidade, neutralidade e responsabilidade no uso da internet;
- ABNT NBR ISO/IEC 27001: requisitos para sistemas de gestão de segurança da informação;
- Resolução CFM nº 1.821/2007: normas técnicas para digitalização e uso dos sistemas informatizados para a guarda e manuseio de prontuários.

9.2. Gerenciamento de vulnerabilidades e patches

Implementar um processo formal para identificação, avaliação, priorização e correção de vulnerabilidades de segurança nos sistemas e aplicativos da rede. A aplicação de patches de segurança deve seguir um calendário regular, com priorização baseada na criticidade da vulnerabilidade (CVSS) e no impacto potencial sobre os serviços hospitalares. Atualizações críticas devem ser aplicadas em até 72 horas após sua disponibilização.

10. Responsabilidades

10.1. Direção

A direção da Rede Hospitalar Cuidar é responsável por estabelecer, apoiar e patrocinar esta Política de Segurança da Informação, garantindo que os recursos humanos, financeiros e tecnológicos adequados sejam alocados para sua implementação e manutenção. A oficialização desta política se dá por meio de carta formal da presidência, comunicada a todos os colaboradores.

10.2. Equipe de segurança da informação

A equipe de TI e segurança da informação é responsável pela implementação técnica, monitoramento contínuo e manutenção das políticas e práticas de segurança definidas neste documento, bem como pela coordenação da resposta a incidentes de segurança e pela gestão das ferramentas de monitoramento, incluindo o Zabbix Appliance.

10.3. Funcionários

Todos os colaboradores da Rede Hospitalar Cuidar, independentemente do cargo ou função, são responsáveis por conhecer, respeitar e aplicar as diretrizes estabelecidas nesta PSI, por utilizar os sistemas de informação de forma segura e responsável, e por comunicar imediatamente à equipe de TI qualquer incidente, suspeita de violação ou comportamento anômalo identificado nos sistemas.

. Glossário

Este glossário reúne os principais termos e siglas utilizados nesta Política de Segurança da Informação, visando garantir o entendimento uniforme do documento por todos os colaboradores da Rede Hospitalar Cuidar, independentemente de sua área de atuação.

ANPD: Autoridade Nacional de Proteção de Dados. Órgão federal brasileiro responsável por fiscalizar e aplicar a LGPD.

Ativo de Informação: Qualquer dado, sistema, equipamento ou recurso que tenha valor para a organização e que necessite de proteção.

CFM: Conselho Federal de Medicina. Órgão regulador da prática médica no Brasil.

CVSS: Common Vulnerability Scoring System. Sistema padronizado de pontuação para avaliar a severidade de vulnerabilidades de segurança.

DDoS: Distributed Denial of Service. Ataque que visa tornar um serviço indisponível por meio do envio massivo de requisições simultâneas.

Domínio minasgerais.net: Domínio Active Directory utilizado pela Rede Hospitalar Cuidar para centralizar a autenticação e o gerenciamento de políticas de acesso.

GPO: Group Policy Object. Objeto de Política de Grupo utilizado no Active Directory para aplicar configurações e restrições a usuários e computadores do domínio.

LGPD: Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018). Lei brasileira que regula o tratamento de dados pessoais.

MFA: Multi-Factor Authentication. Autenticação Multifator. Método de autenticação que exige mais de uma forma de verificação de identidade.

Prontuário Eletrônico: Registro digital do histórico clínico de um paciente, contendo informações médicas sensíveis protegidas pela LGPD e pelo CFM.

PSI: Política de Segurança da Informação. Documento formal que estabelece diretrizes para proteção dos ativos de informação de uma organização.

RBAC: Role-Based Access Control. Controle de Acesso Baseado em Função. Modelo de controle de acesso em que as permissões são atribuídas conforme o papel do usuário.

UPA: Unidade de Pronto Atendimento. Unidades remotas da Rede Hospitalar Cuidar (UPA 1, UPA 2 e UPA 3).

VPC: Virtual Private Cloud. Rede virtual isolada na AWS utilizada pela Rede Hospitalar Cuidar para hospedar sua infraestrutura em nuvem (10.0.0.0/16).

Zabbix: Plataforma de monitoramento de infraestrutura de TI utilizada pela Rede Hospitalar Cuidar para coleta e análise de telemetria dos servidores.

. Referências

- ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO/IEC 27001: Tecnologia da informação — Técnicas de segurança — Sistemas de gestão da segurança da informação — Requisitos. Rio de Janeiro: ABNT, 2013.
- BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 2018.

- BRASIL. Lei nº 12.965, de 23 de abril de 2014. Marco Civil da Internet. Diário Oficial da União, Brasília, DF, 2014.
- CONSELHO FEDERAL DE MEDICINA. Resolução CFM nº 1.821/2007. Normas técnicas para digitalização e uso dos sistemas informatizados para a guarda e manuseio dos prontuários dos pacientes. Brasília: CFM, 2007.
- OWASP FOUNDATION. OWASP Top Ten 2021. Disponível em: <https://owasp.org/www-project-top-ten/>. Acesso em: jun. 2026.

Aprovado e oficializado pela Direção Geral da Rede Hospitalar Cuidar

Direção Geral — Rede Hospitalar Cuidar
Belo Horizonte, Junho de 2026